Nota tecnica preliminare — incidente IR-27-0216

OSTIGLIA DIGITAL FORENSICS S.r.l. Laboratorio di informatica forense — Via Zamboni 47, 40126 Bologna C.F. e P.IVA 03998710376 — info@ostigliadf.example — pronto intervento 800 552 118

Rif. IR-27-0216/FOR-01 — Bologna, 16 febbraio 2027, ore 11:40 Committente: Saliceto Salute Digitale S.p.A. — Direzione sicurezza delle informazioni Referente del committente: ing. Marta Bellandi Redattore: ing. Marco Tibaldi, perito in informatica forense, iscritto all'Albo dei consulenti tecnici del Tribunale di Bologna al n. 1187 Classificazione: riservato

1. Incarico

Con richiesta di intervento urgente trasmessa alle ore 08:52 del 16 febbraio 2027 e confermata per iscritto alle ore 09:20, la Direzione sicurezza delle informazioni del committente ha affidato allo scrivente le attività di analisi tecnica sull'incidente registrato con identificativo IR-27-0216. Il gruppo di lavoro è presente presso la sede di Bologna dalle ore 09:40. La presente nota riferisce quanto accertato alle ore 11:40 ed è per sua natura provvisoria: le conclusioni potranno essere confermate, integrate o modificate all'esito delle analisi in corso.

2. Quesiti posti

1. Individuare il momento iniziale dell'attività ostile e le modalità di accesso.
2. Accertare se vi sia stato trasferimento di dati verso l'esterno e, in tal caso, quantificarne il volume e individuarne il contenuto.
3. Indicare le misure necessarie a preservare gli elementi di prova nel corso del ripristino.

3. Materiale esaminato

Sono stati esaminati, nello stato in cui si trovavano al momento dell'intervento: i log del firewall perimetrale dal 1° febbraio 2027; le tracce NetFlow del medesimo periodo; i registri di autenticazione dei servizi di directory; la telemetria dell'agente EDR sugli host segnalati; il rapporto SOC/IR-27-0216 emesso alle ore 08:20; l'export del ticket KAI-SEC-7781 del fornitore Kairone S.r.l. con i relativi indicatori; i campioni della nota di riscatto rinvenuti sulle condivisioni cifrate. Le acquisizioni effettuate dal committente prima del nostro arrivo sono state prese in carico con verbale di consegna allegato.

4. Metodo

Le copie sono state acquisite in sola lettura mediante blocco in scrittura hardware per i supporti fisici e mediante snapshot in modalità non alterante per le macchine virtuali. Per ciascuna copia è stata calcolata l'impronta SHA-256 all'atto dell'acquisizione e verificata al termine. Le analisi sono condotte su copie di lavoro; i reperti originali non sono utilizzati. Ogni passaggio di custodia è annotato sul modulo CDC/2027/0216 con data, ora, soggetto ricevente e stato dei sigilli.

5. Esiti preliminari

5.1 Persistenza. Gli indicatori più antichi finora individuati risalgono al 12 febbraio 2027: alle ore 21:34 di quel giorno si registra la prima autenticazione anomala verso un servizio di accesso remoto, seguita da attività di ricognizione interna nei giorni successivi. L'attività si è quindi svolta per più giorni prima della fase di cifratura. Non è stato ancora determinato il punto di ingresso iniziale; sono in corso verifiche sulle sessioni VPN dei profili fornitore e sui messaggi di posta ricevuti nella settimana precedente.

5.2 Credenziali. Risultano utilizzate credenziali privilegiate appartenenti a due account di servizio del dominio. Le autenticazioni sono avvenute in orari e da postazioni non coerenti con l'uso ordinario dei medesimi account. Gli account sono stati disabilitati su indicazione del committente alle ore 08:35; le password amministrative sono state ruotate.

5.3 Trasferimenti verso l'esterno. I log del perimetro e le tracce NetFlow documentano trasferimenti cifrati verso due indirizzi non compresi nelle destinazioni consentite, distribuiti in sei sessioni tra il 14 e il 16 febbraio 2027, l'ultima delle quali chiusa alle ore 08:07 del 16 febbraio. Il volume complessivo misurato in uscita è di 62 GB. Il dato è confermato dalla misura di rete su entrambe le sorgenti indipendenti (firewall e sonda NetFlow).

5.4 Cifratura. La cifratura ha interessato due file server e la condivisione principale del repository referti, con estensione aggiunta .lkq7. I sistemi di backup non presentano tracce delle catene di esecuzione rilevate e i punti di ripristino verificati risultano leggibili.

6. Limiti dell'accertamento allo stato attuale

Il volume di 62 GB è una misura di traffico e non una misura di contenuto. Alla data e all'ora della presente nota non è noto quali record compongano l'intero volume trasferito: la corrispondenza tra i byte usciti dal perimetro e i file, le tabelle e le posizioni presenti nei sistemi di origine richiede la ricostruzione degli accessi applicativi e l'analisi dei sistemi sorgente, attività avviata e non conclusa. Non è pertanto possibile, allo stato, indicare quante e quali posizioni siano interessate dal trasferimento, né escludere che parte del volume sia costituita da dati non riferibili a persone fisiche.

Le sessioni documentate hanno come origine sistemi che, secondo l'inventario del committente, trattano anche dati clinici; questa circostanza non consente da sola di attribuire a ciascuna sessione un contenuto determinato.

Si propone un primo punto di verifica alle ore 18:00 di oggi, con la restituzione dei risultati sull'analisi dei sistemi di origine disponibili a quell'ora, e una successiva integrazione scritta della presente nota. Ulteriori punti di verifica saranno concordati con cadenza giornaliera.

7. Conservazione degli elementi di prova

Prima di qualsiasi attività di ripristino devono essere acquisite le immagini dei sistemi interessati, calcolate le impronte hash dei file rilevanti e conservata copia integrale dei log, compresi quelli soggetti a rotazione automatica, la cui finestra di conservazione è di quindici giorni e rischia di sovrascrivere le tracce del periodo iniziale. Devono essere conservati anche i messaggi originali ricevuti, con le intestazioni complete.

Ogni passaggio va registrato nella catena di custodia. Le attività di ripristino e quelle di analisi possono procedere in parallelo purché il ripristino avvenga su ambienti distinti da quelli acquisiti e i supporti originali restino sigillati. Si raccomanda di annotare in un registro delle decisioni, con data e ora, ogni scelta operativa che incida sui sistemi interessati e il soggetto che l'ha assunta.

8. Attività in corso

Ricostruzione degli accessi applicativi sui sistemi di origine; analisi dei registri del repository referti; esame delle sessioni VPN dei profili fornitore; ricerca di ulteriori indicatori nel periodo antecedente il 12 febbraio; verifica dell'eventuale presenza di strumenti di persistenza residui.

Il perito ing. Marco Tibaldi

Allegati: verbale di consegna dei reperti; modulo di catena di custodia CDC/2027/0216; elenco degli indicatori di compromissione (rev. 1).

IR-27-0216/FOR-01 — pag. 1 di 4